IFCT0109 · MF0489_3 · Sistemas Seguros de Acceso y Transmision de Datos

INFRAESTRUCTURA DE CLAVE PUBLICA

PKI · Public Key Infrastructure

Unidad Didactica 2

CONTENIDOS DE LA UNIDAD

01
Que es una PKI
Definicion, necesidad y modelo de confianza

02
Componentes de la PKI
CA, RA, repositorio, usuario final

03
Autoridad de Certificacion
Tipos de CA, jerarquia, CA raiz e intermedia

04
Politica y CPS
Politica de certificado y declaracion de practicas

05
CRL y OCSP
Revocacion de certificados, listas y consulta en tiempo real

06
CSR y ciclo de vida
Solicitud, emision, renovacion y revocacion

07
PMI y certificados de atributo
Infraestructura de gestion de privilegios

08
Aplicaciones PKI
HTTPS, email, DNIe, firma electronica, VPN

QUE ES UNA PKI

Una PKI es el conjunto de hardware, software, politicas y procedimientos necesarios para crear, gestionar, distribuir, usar, almacenar y revocar certificados digitales y gestionar el cifrado de clave publica.

El problema que resuelve:

Sin PKI

Como saber que la clave publica que recibes pertenece realmente a quien dice ser? Cualquiera puede crear un par de claves y hacerse pasar por otro.

Con PKI

Una Autoridad de Certificacion (CA) de confianza firma digitalmente el certificado, garantizando que la clave publica pertenece a la identidad declarada.

COMPONENTES DE UNA PKI

CA - Autoridad de Certificacion

Entidad de confianza que emite y firma certificados digitales. Es el nucleo de la PKI.

RA - Autoridad de Registro

Verifica la identidad de los solicitantes antes de que la CA emita el certificado.

Repositorio de certificados

Base de datos publica donde se publican los certificados emitidos y las CRL.

Usuario final (EE)

Persona, servidor o dispositivo que posee un certificado y lo usa para comunicarse.

Infraestructura de validacion

Servicios OCSP y CRL que permiten comprobar si un certificado sigue siendo valido.

Sistema de gestion de claves

Custodia y recuperacion de claves privadas en entornos corporativos.

JERARQUIA DE AUTORIDADES DE CERTIFICACION

CA RAIZ (Root CA)

Autofirmada · Maxima confianza · Siempre offline

CA Intermedia Usuarios

- Cert. usuario
- Cert. servidor
- Cert. corpweb

CA Intermedia Servidores

- Cert. nginx
- Cert. router

CA Intermedia Dispositivos

- Cert. IoT

Cadena de confianza: El certificado final es de confianza porque esta firmado por una CA intermedia, que a su vez esta firmada por la CA raiz, que es de confianza publica.

CERTIFICADO DIGITAL X.509

Campos del certificado X.509 v3

Version:	v1, v2, v3 (actual)
Numero de serie:	Identificador unico en la CA
Algoritmo de firma:	SHA256withRSA, ECDSA...
Emisor (Issuer):	DN de la CA que lo firma
Validez:	notBefore / notAfter
Sujeto (Subject):	DN del titular del cert.
Clave publica:	Algoritmo + valor de la clave
Extensiones v3:	SAN, KeyUsage, CRL, OCSP...
Firma digital:	Firmado por la CA emisora

Formatos de certificado

PEM `.pem .crt .cer`

Base64 con cabeceras -----BEGIN CERTIFICATE-----. El mas comun en Linux/web.

DER `.der .cer`

Binario. Mismo contenido que PEM pero sin codificar en Base64. Usado en Java y Windows.

PKCS# 12 `.p12 .pfx`

Contiene certificado + clave privada protegidos con contrasena. Para importar en navegadores.

PKCS# 7 `.p7b .p7c`

Solo certificados, sin clave privada. Cadenas de confianza y respuestas CMS.

POLITICA DE CERTIFICADO Y CPS

CP - Certificate Policy

Define QUE hace la CA y QUE garantiza. Es el documento de alto nivel que establece las reglas de uso de los certificados.

- Para que tipos de entidades emite certificados
- Nivel de validacion de identidad requerido
- Usos permitidos y prohibidos del certificado
- Obligaciones del titular del certificado
- Periodo de validez maximo permitido

CPS - Certification Practice Statement

Define COMO lo hace la CA. Documento tecnico y legal que describe los procedimientos operativos de la CA.

- Procedimiento de verificacion de identidad
- Proceso tecnico de emision de certificados
- Medidas de seguridad fisica y logica de la CA
- Procedimiento de revocacion y tiempos maximos
- Plan de continuidad y recuperacion ante desastres

REVOCACION DE CERTIFICADOS: CRL Y OCSP

Un certificado puede necesitar invalidarse antes de su fecha de caducidad:

- Clave privada comprometida
- El titular ya no esta autorizado
- La CA fue comprometida
- Cambio de datos del titular

CRL - Certificate Revocation List

Lista firmada por la CA con todos los numeros de serie revocados.

Como funciona:
1. La CA publica la CRL periodicamente
2. El cliente descarga la CRL completa
3. Comprueba si el numero de serie esta en la lista

Ventaja: Simple, no requiere conectividad en tiempo real
Desventaja: La CRL puede ser muy grande y estar desactualizada

OCSP - Online Certificate Status Protocol

Consulta en tiempo real al servidor OCSP de la CA.

Como funciona:
1. El cliente envia el numero de serie al OCSP
2. El OCSP responde: good / revoked / unknown
3. La respuesta esta firmada por la CA

Ventaja: Respuesta inmediata, no descarga listas grandes
Desventaja: Requiere conectividad, puede revelar que certificados se usan

CSR Y CICLO DE VIDA DEL CERTIFICADO

1. Generar par de claves
2. Crear CSR (PKCS#10)
3. Enviar CSR a la CA
4. CA verifica identidad
5. CA firma y emite cert.
6. Instalar certificado

Contenido de un CSR (PKCS#10):

Subject DN:	CN=www.empresa.es, O=Empresa SA, C=ES
Clave publica:	La clave publica del solicitante
Algoritmo:	RSA 2048, ECDSA P-256...
Firma:	Con la clave privada del solicitante
Extensiones:	SAN, KeyUsage solicitados

Ciclo de vida del certificado:

EMITIDO	Certificado valido y en uso
SUSPENDIDO	Temporalmente invalido, puede reactivarse
RENOVADO	Nuevo periodo de validez, misma identidad
REVOCADO	Invalidado permanentemente, aparece en CRL
CADUCADO	Expirado por fecha, ya no es valido

PMI - INFRAESTRUCTURA DE GESTION DE PRIVILEGIOS

PKI gestiona IDENTIDAD · PMI gestiona AUTORIZACION y PRIVILEGIOS

PKI	PMI
• Quien eres (identidad)	• Que puedes hacer (privilegios)
• Certificado de identidad	• Certificado de atributo
• Clave publica del titular	• Referencia al cert. de identidad
• Emitido por una CA	• Emitido por una AA (Attribute Authority)
• Largo periodo de validez	• Corto periodo de validez

APLICACIONES QUE USAN PKI

HTTPS / TLS

Certificados de servidor para cifrar el trafico web. Navegadores verifican la cadena de confianza contra las CA raiz instaladas.

DNIe y firma electronica

El DNI electronico es un certificado X.509 emitido por la FNMT. Permite autenticarse y firmar documentos con validez legal (Ley 59/2003).

S/MIME - Email seguro

Certificados de usuario para cifrar y firmar emails. Compatible con Outlook, Thunderbird.

VPN con certificados

IPSec e OpenVPN usan certificados PKI para autenticar los extremos del tunel en lugar de usuario/contrasena.

Autenticacion 802.1X

Acceso a red corporativa con certificado de dispositivo/usuario. Solo dispositivos con certificado valido se conectan.

Firma de codigo

Fabricantes firman sus aplicaciones para garantizar autenticidad e integridad. Windows SmartScreen, AppStore.

RESUMEN DE LA UNIDAD

01 Una PKI es el conjunto de componentes que permite crear, gestionar y revocar certificados digitales de forma segura

02 La CA es el nucleo de confianza. La jerarquia CA Raiz → CA Intermedia → Certificado final forma la cadena de confianza

03 El certificado X.509 v3 vincula una identidad (Subject) a una clave publica, firmado por la CA emisora

04 CP define QUE garantiza la CA. CPS define COMO lo hace. Ambos documentos son publicos y de obligado cumplimiento

05 CRL y OCSP permiten comprobar si un certificado ha sido revocado antes de su fecha de caducidad

06 PKI = identidad. PMI = privilegios. HTTPS, DNIe, VPN, email seguro y firma de codigo son aplicaciones reales de PKI